VERIQTA

Cyber Threat Intelligence

From Zero



THREAT INTELLIGENCE

MALWARE

THREAT ACTORS

INDICATORS OF COMPROMISE

OSINT

MITRE ATT&CK

THREAT ANALYSIS

DEFENSIVE ACTIONS

PRACTICAL EXAMPLES | REAL-WORLD SCENARIOS | BEGINNER FRIENDLY | SKILLS FOR SOC & THREAT HUNTING

@veriqta | @veriqta | @veriqta | @veriqta | @veriqta | @veriqta

What Is Cyber Threat Intelligence?

1. What Is Cyber Threat Intelligence (CTI)?

- Cyber Threat Intelligence (CTI) is evidence-based information about current or potential cyber threats.
- It helps organizations understand who the attackers are, what they do, and how to defend against them.
- CTI turns raw data into useful insights that support real security decisions.

2. Why Organizations Need CTI

- Helps detect attacks early.
- Improves incident response.
- Guides proactive threat hunting.
- Supports risk management.
- Informs security controls and policies.
- Reduces the impact of cyberattacks.

3. From Data to Intelligence

RAW DATA

Individual facts without context.

- IP address
- Domain name
- File hash
- Log entry
- Email address

INFORMATION

Data with context and meaning.

- IP address linked to a malicious domain
- Domain associated with a phishing campaign
- File hash seen in malware reports

INTELLIGENCE

Analyzed information that supports decisions.

- This IP is part of a known ransomware campaign
- The domain is used to target financial institutions
- Recommendation: block the IP and monitor for related activity

4. How CTI Helps Defenders

Detect
Identify malicious activity faster.

Investigate
Understand the full scope of an attack.

Respond
Take the right action.

Prevent
Block known malicious indicators.

Decide
Make informed security and business decisions.

5. Practical Example: From IP to Intelligence

Step 1: Raw Data

Suspicious IP address: 185.199.110.153

Step 2: Add Context (Information)

- IP is linked to a malicious domain.
- Seen in threat intelligence databases.
- Associated with a phishing campaign targeting Microsoft 365 users.

Step 3: Intelligence (Actionable Insight)

- This IP is part of a phishing infrastructure.
- It is used to steal login credentials.
- Recommended action: block the IP, monitor for related activity, and inform users about the campaign.

6. Key Takeaway

Cyber Threat Intelligence turns scattered data into clear, actionable insights that help organizations detect, prevent, and respond to cyber threats.

Understanding Cyber Threats and Threat Actors

1. Common Cyber Threats

Malware
- Malicious software such as viruses, trojans, worms and spyware.
- Used to steal data, disrupt systems or gain access.

Phishing
- Fake emails, messages or websites.
- Tricks users into revealing sensitive information like passwords.

Ransomware
- Malware that encrypts your files.
- Attackers demand payment to restore access.

Credential Theft
- Steals usernames, passwords and other credentials.
- Used to gain unauthorized access to systems and data.

2. Types of Threat Actors

Cybercriminals
- Motivated by financial gain.
- Carry out ransomware, fraud and data theft.
- Often operate in groups.

Insider Threats
- Current or former employees.
- May be malicious or accidental.
- Can leak data or misuse access.

Hacktivists
- Motivated by political or social causes.
- Attack organizations to make a statement.
- Often target governments and large companies.

State-Sponsored Actors
- Backed by a country.
- Conduct espionage, sabotage or influence operations.
- Usually well funded and highly skilled.

3. Key Security Terms

Term	What It Means	Simple Example
Threat	A potential danger that can cause harm.	A hacker who wants to steal your data.
Vulnerability	A weakness in a system, application or process.	An unpatched software flaw.
Exploit	A method used to take advantage of a vulnerability.	A piece of code that uses the software flaw to gain access.
Risk	The likelihood and impact of a threat exploiting a vulnerability.	The chance that a hacker will use the flaw to steal data and the damage it can cause.

4. How They Are Connected

Threat (hacker) → Uses an exploit → Targets a vulnerability → This creates a risk (data loss)

5. Practical Example: Investigating a Phishing Campaign

1. **Receive the email**
   A user reports a suspicious email.
2. **Inspect the sender**
   Check the email address and domain.
3. **Analyze the content**
   Look for suspicious links, urgent language and attachment.



4. **Check the link or domain**
   Use a tool like VirusTotal or URLhaus (without clicking).
5. **Review findings**
   Determine if it is part of a known phishing campaign.
6. **Take action**
   Block the domain, warn users and update security controls.

6. Key Takeaways

- Cyber threats come in different forms such as malware, phishing, ransomware and credential theft.
- Threat actors have different motivations and capabilities.
- A threat, vulnerability, exploit and risk are related but mean different things.
- Understanding threats and threat actors helps you detect, prevent and respond to attacks.

The Four Types of Threat Intelligence

1. What Are the Four Types of Threat Intelligence?

- Threat intelligence can be grouped into four types: **Strategic, Tactical, Operational** and **Technical**.
- Each type serves a different purpose and is used by different people in an organization.
- All four types work together to give a complete understanding of cyber threats.



2. The Four Types Explained

Strategic Threat Intelligence

- High-level, long-term view of cyber threats.
- Used by executives, management and business leaders.
- Helps with risk management, resource allocation and security strategy.

Examples

- Emerging threat trends
- Geopolitical risks
- Industries being targeted
- Potential business impact

Tactical Threat Intelligence

- Focuses on attacker techniques, tactics and procedures (TTPs).
- Helps defenders improve detection and response.
- Used by SOC teams, incident responders and threat hunters.

Examples

- MITRE ATT&CK techniques
- Common attacker tools
- Attack patterns and methods
- Detection opportunities

Operational Threat Intelligence

- Focuses on specific campaigns, threat actors and their infrastructure.
- Helps track current or ongoing attacks.
- Used by SOC teams, incident responders and intelligence teams.

Examples

- Active phishing campaign
- Threat actor infrastructure
- Malicious domains and IPs
- Campaign timelines

Technical Threat Intelligence

- Focuses on technical indicators such as IP addresses, domains, URLs and file hashes.
- Used to detect and block malicious activity.
- Used by SOC teams, security tools and defenders.

Examples

- Malicious IP addresses
- Suspicious domains
- Malicious URLs
- File hashes (MD5, SHA256)
- YARA rules

3. How the Four Types Work Together

Strategic — Identifies bigger risks and trends → **Tactical** — Explains attacker techniques → **Operational** — Tracks real campaigns and threat actors → **Technical** — Provides concrete indicators

4. Practical Example: How Different Teams Use the Same Threat Report

Threat Report

New phishing campaign targeting financial institutions using a malicious domain.

Business/Leadership (Strategic)

- Understands the potential business impact.
- Decides on risk reduction and resource allocation.
- May update security strategy or policies.

SOC / Incident Response (Tactical)

- Reviews attacker techniques used in the campaign.
- Creates or updates detection rules.
- Prepares the team for possible attacks.

Threat Intelligence Team (Operational)

- Tracks the campaign and the threat actor.
- Monitors related domains, IPs and infrastructure.
- Shares findings with defense teams.

Security Tools / Engineers (Technical)

- Uses the provided IP addresses, domains and file hashes.
- Blocks indicators in firewalls, EDR and SIEM.
- Searches environment for any matches.

5. Key Takeaways

- Each type of threat intelligence serves a different purpose.
- All four types are important and work together.
- The same threat report can be used by different teams in different ways.
- Understanding these types helps you know how CTI supports real security work.

The Threat Intelligence Lifecycle

VERIQTA

1. DIRECTION

- Define intelligence requirements.
- Identify what you need to know.
- Align with business and security goals.

Examples

- Are we being targeted?
- What are the latest threats to our industry?
- What indicators should we monitor?

2. COLLECTION

- Gather relevant evidence from multiple sources.
- Use open-source, commercial and internal sources.
- Collect indicators, reports, logs and observations.

Examples

- Threat intelligence feeds
- OSINT (public sources)
- Internal logs and alerts
- Community reports

3. PROCESSING

- Organize and prepare collected data.
- Remove duplicates and irrelevant data.
- Normalize and enrich the data (for example, add context).

Examples

- Clean and structure indicators
- Enrich with additional information
- Convert data into a usable format
- Tag and categorize



4. ANALYSIS

- Evaluate evidence and produce findings.
- Identify patterns, trends and attacker behavior.
- Assess credibility and confidence.
- Turn data into actionable intelligence.

Examples

- Identify a phishing campaign
- Link related indicators
- Assess the threat actor's goal
- Determine the potential impact

5. DISSEMINATION

- Deliver intelligence to the right people in the right format.
- Tailor the message for different audiences.
- Provide clear, actionable recommendations.

Examples

- Executive summary for leadership
- Technical report for SOC teams
- Actionable indicators for security tools
- Briefing for IT and risk teams

6. FEEDBACK

- Improve future intelligence work.
- Assess the usefulness of the intelligence.
- Adjust requirements, sources and methods.

Examples

- Was the intelligence useful?
- What did we miss?
- Do we need new data sources?
- How can we improve?

7. PRACTICE: Build a Simple Intelligence Workflow

1. Choose a real threat (e.g., a recent phishing campaign).
2. Define 2–3 intelligence questions.
3. Collect evidence from open-source sources.
4. Clean and organize the data.
5. Analyze the findings and identify key insights.
6. Present a short report with recommendations.

8. Key Takeaways

- The Threat Intelligence Lifecycle helps turn raw data into actionable intelligence.
- Each stage plays an important role and depends on the others.
- Good intelligence is accurate, relevant, timely and actionable.
- Continuous feedback improves the quality and value of future intelligence.

Open-Source Intelligence (OSINT) Fundamentals

1. What Is OSINT?

- OSINT (Open-Source Intelligence) is information collected from **publicly available sources.**
- CTI analysts use OSINT to understand **threat actors, campaigns and infrastructure.**
- It helps turn public information into useful intelligence for security decisions.

2. Common OSINT Sources

Websites & Blogs
News, security blogs, company websites

Domain Records
WHOIS, RDAP, DNS records

Security Reports
Vendor reports, threat research

Social Media
Public posts, profiles, forums

Threat Databases
VirusTotal, AlienVault OTX, URLhaus, etc.

Code Repositories
GitHub, paste sites, leaked data (public)

3. How CTI Analysts Use OSINT

Investigate
Find information about indicators (IPs, domains, files, threat actors).

↓

Connect
Link related data from multiple sources to see the bigger picture.

↓

Understand
Identify attacker behaviour, campaigns and infrastructure.

↓

Support Decisions
Provide evidence to help teams detect, prevent and respond.

4. Legal, Ethical and Privacy Boundaries

Legal
- Use publicly available information only.
- Follow local laws and platform terms of service.
- Do not hack, access private data or bypass controls.

Ethical
- Use OSINT for defensive and educational purposes.
- Do not harass, dox or target individuals.
- Be responsible and avoid causing harm.

Privacy
- Do not collect or share personal data unnecessarily.
- Avoid exposing innocent individuals.
- Remove or anonymize sensitive personal information in your reports.

5. Useful OSINT Tools for Beginners

VirusTotal
Analyze files, URLs, domains and IP addresses.

AlienVault OTX
Community threat intelligence.

URLhaus
Malicious URLs database.

AbuseIPDB
IP address reputation.

GitHub
Search for exposed code and security research.

WHOIS / RDAP
Domain registration information.

DNS Lookup
Check DNS records and historical data.

Shodan
Find internet-connected devices.

Google / Search
Find news, reports and public information.

Wayback Machine
View historical versions of websites.

6. Practical Example: Research a Public Cyberattack

1. **Choose a real attack**
   Example: A well-known ransomware campaign (such as LockBit).
2. **Search for public reports**
   Find articles and threat reports about the campaign.
3. **Identify key indicators**
   Look for domains, IP addresses, file hashes or TTPs.
4. **Use OSINT tools**
   Check the indicators in tools like VirusTotal, OTX and WHOIS.
5. **Summarize your findings**
   Who is behind it? What are their targets? What tools do they use?

7. Key Takeaways

- OSINT is a powerful source of information for threat intelligence.
- CTI analysts use public data to understand attackers and their infrastructure.
- Many useful sources are free and accessible to anyone.
- You must follow legal and ethical guidelines and respect privacy.
- With practice, you can turn public information into valuable intelligence.

Your First Threat Intelligence Toolkit

1. What You Will Learn

- Introduce VirusTotal, AlienVault OTX, URLhaus, and AbuseIPDB.
- Understand what each platform can and cannot establish.
- Learn how to investigate without visiting suspicious websites.
- Practice: Examine a publicly documented malicious indicator.

2. The Threat Intelligence Toolkit

VirusTotal
- Analyze files, URLs, domains and IP addresses.
- Uses multiple security engines.
- Shows community insights.

AlienVault OTX
- Community-driven threat intelligence.
- Information about malicious IPs, domains, URLs and threat actors.
- Useful for researching campaigns and indicators.

URLhaus
- Database of malicious URLs.
- Focuses on malware, phishing and botnet URLs.
- Provides metadata and related samples.

AbuseIPDB
- Check IP address reputation.
- View reports from the community.
- See abuse types and confidence scores.

3. What Each Tool Can and Cannot Establish

Tool	What It Can Establish	What It Cannot Establish	Best Used For
VirusTotal	✓ Shows detection results from multiple security engines. ✓ Provides details about files, URLs, domains and IPs.	✗ Does not confirm intent or attribution. ✗ May contain false positives. ✗ Does not fully explain the bigger campaign.	Initial investigation and quick reputation checks.
AlienVault OTX	✓ Community reports about malicious indicators. ✓ Related threat actor and campaign information.	✗ Does not guarantee accuracy. ✗ Information may be limited. ✗ Does not provide full attribution.	Researching campaigns, related indicators and threat actor activity.
URLhaus	✓ Confirmed malicious URLs with metadata. ✓ Shows related malware and HTTP details.	✗ Does not analyze files. ✗ Limited information about the full campaign. ✗ Does not provide attribution.	Investigating malicious URLs used in malware and phishing campaigns.
AbuseIPDB	✓ Community reports about IP addresses. ✓ Shows abuse type, country, ISP and last seen information.	✗ Does not confirm malicious intent. ✗ Reports can be outdated or wrong. ✗ Does not provide full context on the campaign.	Checking IP reputation and seeing real-world abuse reports.

4. How to Investigate Safely (Without Visiting Sites)

- Do not click on suspicious links.
- Use online analysis tools like VirusTotal, URLhaus and OTX.
- Use a sandbox environment if you must open a file or website.
- Read reports from trusted security sources.
- Always verify information from multiple sources.
- Avoid sharing sensitive data.

5. Practical Example: Examine a Malicious Indicator

1. **Choose a real indicator**
   Example: a known phishing URL or suspicious IP address.
2. **Check it on VirusTotal**
   Look at detection results, community comments and details.
3. **Check it on URLhaus or OTX**
   Find additional information about the indicator.
4. **Check IP reputation (if it is an IP address)**
   Use AbuseIPDB to see reports and abuse type.
5. **Summarize your findings**
   What is the indicator? What is it used for? What is the risk?

6. Key Takeaways

- These tools help you collect and understand threat intelligence from public sources.
- Each tool has strengths and limitations, so use multiple sources.
- You can investigate indicators without visiting suspicious websites.
- Always consider accuracy, context and the possibility of false positives.
- Practice with publicly documented indicators to build your skills.

Indicators of Compromise (IOCs)

1. What Are Indicators of Compromise?

- IOCs are pieces of evidence that may indicate malicious activity.
- Common examples include suspicious IP addresses, domains, URLs and file hashes.
- They help security teams detect, investigate and respond to threats.
- An IOC is a clue, not full proof of malicious activity. It needs analysis and context.

2. Common Types of IOCs

IP Address
- Identifies a device on a network.
- Can be used for malicious activities such as hosting malware or command and control.

Example: 185.199.110.153

Domain
- A website address used by attackers.
- Can be used for phishing, malware distribution or command and control.

Example: malicious-site.com

URL
- Specific web address used in attacks.
- Often used in phishing or to deliver malware.

Example: http://malicious-site.com/login

File Hash
- A unique fingerprint of a file.
- Used to identify malicious files.
- Common types: MD5, SHA1, SHA256.

Example: 44d88612fea8a8f36de82e1278abb02f (MD5)

3. IOC vs Proof of Malicious Activity

Indicator of Compromise (IOC)	Proof of Malicious Activity
A potential sign of malicious activity.	Confirmed evidence of malicious activity.
Needs analysis and context.	Requires multiple sources of evidence.
Can be false positive or irrelevant.	Shows clear intent or impact.
Used for detection and investigation.	Used to confirm an incident.

4. Why Indicators Expire or Become Unreliable

Infrastructure changes
- Attackers frequently change IPs, domains and URLs.

Domains get taken down
- Malicious domains may be shut down by law enforcement or hosting providers.

IP addresses are reused
- A previously malicious IP can be reassigned to a legitimate user.

Evasion techniques
- Attackers use fast-flux, domain generation and other methods to avoid detection.

Lack of context
- An indicator without context can be misleading or a false positive.

5. Examples of Real IOCs

Type	Example	What It Indicates
IP Address	185.199.110.153	Known to host malware or C2 infrastructure.
Domain	malicious-site.com	Used in phishing campaign.
URL	http://malicious-site.com/login	Fake login page to steal credentials.
File Hash (SHA256)	d2e8974f3f8a1c9e5b6c49e1a5f2d3c7b8e9f0a1c2d3e4f5a6b7c8d9e0f1	Malicious file (e.g., trojan or ransomware).

6. How to Analyze an IOC

1. **Identify the IOC type** (IP, domain, URL or file hash).
2. **Check reputation** Use tools like VirusTotal, AbuseIPDB, OTX or WHOIS.
3. **Look for additional context** Find related reports, samples or threat actor information.
4. **Determine the risk** Assess if it is likely malicious, suspicious or benign.
5. **Take action** Use the findings to inform detection, blocking or further investigation.

7. Practice: Examine and Classify Sample IOCs

#	Indicator	Type	Likely Malicious?	Notes
1	91.200.12.34	IP Address	[ ] Yes [ ] No [ ] Unknown	_____
2	evil-domain.com	Domain	[ ] Yes [ ] No [ ] Unknown	_____
3	http://bad-site.com/login	URL	[ ] Yes [ ] No [ ] Unknown	_____
4	5f4dcc3b5aa765d61d8327deb882cf99	File Hash (MD5)	[ ] Yes [ ] No [ ] Unknown	_____

8. Key Takeaways

- IOCs are valuable clues for detecting and investigating threats.
- They include IP addresses, domains, URLs and file hashes.
- An indicator is not the same as proof of malicious activity.
- Indicators can expire or become unreliable.
- Always use multiple sources and context when analyzing IOCs.

Investigating Suspicious IP Addresses and Domains

VERIQTA

1. What You Will Learn

- Understand IP reputation, DNS records, and WHOIS/RDAP.
- Investigate suspicious infrastructure using passive tools.
- Learn about shared hosting, false positives, and historical evidence.
- Practice: Analyze a documented suspicious domain.

2. Key Concepts

IP Reputation

- Shows if an IP address is linked to malicious activity.
- Based on reports, community data and historical behaviour.

DNS Records

- Show how a domain is configured.
- Common records: A, AAAA, CNAME, MX, NS, TXT.
- Helps identify hosting and infrastructure.

WHOIS / RDAP

- Shows domain registration details (owner, registrar, actest, nameservers).
- RDAP is the modern, more structured version of WHOIS.

Passive Tools

- Allow you to investigate without interacting with the target.
- Examples: VirusTotal, URLhaus, AbuseIPDB, Shodan, ViewDNS, SecurityTrails.

3. Steps to Investigate a Suspicious IP Address

1. **Check reputation**
   Use tools like VirusTotal or AbuseIPDB.
2. **Look at IP details**
   Identify ISP, country, organization and usage type (hosting, cloud, etc).
3. **Check who is using it**
   Look for related domains, subdomains and reported activity.
4. **Search in multiple sources**
   Compare results from different tools.
5. **Look at historical data**
   Check if it was used in past campaigns.

Example: IP Investigation (VirusTotal)

185.199.110.153

10 / 94 security vendors flagged this IP as malicious

Country	Netherlands
Organization	Hosting Provider
ASN	AS.... (Example: AS16276)
Reputation	Malicious
Last seen	2024-10-12

Detection | Details | Relations | Community

4. Steps to Investigate a Suspicious Domain

1. **Check reputation**
   Use tools like VirusTotal, URLhaus or OTX.
2. **Look at DNS records**
   Find A, AAAA, MX, NS, TXT and CNAME records.
3. **Check WHOIS / RDAP**
   Identify domain registration details.
4. **Look for related infrastructure**
   Find related subdomains, IP addresses and domains.
5. **Check historical data**
   Use tools like SecurityTrails, Shodan or Wayback Machine.

Example: Domain Investigation (ViewDNS)

malicious-site.com — Search

DNS Records | WHOIS/RDAP | IP Info | Subdomains

Type	Value	TTL
A	185.199.110.153	3600
NS	ns1.hostingprovider.net	3600
NS	ns2.hostingprovider.net	3600
MX	mail.malicious-site.com	3600
TXT	v=spf1 -all	3600
AAAA	2a06:98c0:3600::153	3600

5. Shared Hosting and False Positives

Shared Hosting

- Many websites share the same IP address.
- One malicious website can affect the reputation of all sites on the IP.
- Always check the actual domain and context before taking action.

False Positives

- Not all flagged IPs or domains are malicious.
- Security tools can sometimes flag legitimate services.
- Always verify using multiple sources and look at context and historical data.

6. Practical Example: Analyze a Suspicious Domain

Task	What to Do
1. Check reputation	Search the domain in VirusTotal.
2. Review DNS records	Use ViewDNS or DNS checker.
3. Check WHOIS/RDAP	Find registration details.
4. Look for related infrastructure	Find subdomains and IP addresses.
5. Check historical data	Use SecurityTrails or Wayback Machine.
6. Summarize findings	Identify if it is malicious, suspicious or likely safe, and explain why.

7. Key Takeaways

- Investigate IP addresses and domains using multiple passive tools.
- Check reputation, DNS records, WHOIS/RDAP and historical data.
- Be aware of shared hosting and false positives.
- Always look at context before making a conclusion.
- Use documented evidence to support your findings.

- Practical ee Exanlage: Analyze cour a Suspicious Dxamtacturs.
- Ueercle like Cnos, DNS adorains cennu/SdeP and historical data.
- Use aware of shared hosting and false positives.

MITRE ATT&CK for Beginners

1. What You Will Learn

- Understand tactics, techniques and procedures (TTPs).
- Learn how MITRE ATT&CK organizes observed attacker behaviour.
- Explore initial access, execution, persistence and exfiltration.
- Practice: Map a documented phishing attack to ATT&CK techniques.

2. What Is MITRE ATT&CK?

MITRE ATT&CK®

- A globally used knowledge base of real-world attacker behaviour.
- Organizes adversary tactics, techniques and procedures (TTPs).
- Helps security teams, understand, detect and respond to threats.
- Used for threat intelligence, detection engineering, penetration testing and security operations.

3. Key Concepts

Tactic	The attacker's high-level goal (e.g., gain access, maintain access).
Technique	A specific method used to achieve a tactic (e.g., phishing, command and scripting interpreter).
Procedure	The detailed implementation of a technique used by a specific group (e.g., exact tools, commands, files).
TTPs	Tactics, Techniques and Procedures describe the full behaviour of an attacker.

4. Common ATT&CK Tactics (Examples)

Initial Access	Execution	Persistence	Privilege Escalation
Gain a foothold in the target environment.	Run malicious code.	Maintain access over time.	Gain higher permissions.
Example: Phishing (T1566)	Example: Command and Scripting Interpreter (T1059)	Example: Create or Modify System Process (T1543)	Example: Exploitation for Privilege Escalation (T1068)

Defense Evasion	Credential Access	Discovery	Exfiltration
Avoid detection.	Steal user credentials.	Find information about the environment.	Steal data out of the environment.
Example: Obfuscated Files or Information (T1027)	Example: OS Credential Dumping (T1003)	Example: System Information Discovery (T1082)	Example: Exfiltration Over Web Service (T1567)

5. ATT&CK Example: Phishing Attack Flow

Initial Access	Execution	Persistence	Credential Access	Exfiltration
Phishing email (T1566)	Run malicious attachment (T1059)	Create registry run key (T1547)	Steal browser credentials (T1555)	Send data to attacker server (T1567)

6. Mapping a Real Phishing Attack

Stage	Observed Behaviour	ATT&CK Technique (ID)
Initial Access	User clicks malicious link in email.	Phishing (T1566)
Execution	Malicious file runs.	Command and Scripting Interpreter (T1059)
Persistence	Adds registry run key.	Boot or Logon Autostart Execution (T1547)
Credential Access	Steals browser credentials.	Credentials from Web Browsers (T1555)
Exfiltration	Sends data to external server.	Exfiltration Over Web Service (T1567)

7. How to Use ATT&CK in Threat Intelligence

- Analyze threat reports and map TTPs to ATT&CK techniques.
- Improve detection by focusing on known adversary behaviour.
- Understand the full attacker lifecycle and likely next steps.
- Communicate with security teams using a common framework.

8. Key Takeaways

- MITRE ATT&CK helps us understand real attacker behaviour.
- Tactics are goals, techniques are methods, and procedures are the detailed steps.
- It covers the full attack lifecycle from initial access to exfiltration.
- Threat intelligence uses ATT&CK to analyze, detect and respond.
- Mapping attacks to ATT&CK improves visibility and defense.

Understanding the Cyber Kill Chain

1. What You Will Learn

- Explore the stages of the Lockheed Martin Cyber Kill Chain.
- Understand how attackers progress through an intrusion.
- Learn where defenders can detect or disrupt attacks.
- Practice: Trace a simplified ransomware intrusion.

2. What Is the Cyber Kill Chain?

- The Cyber Kill Chain is a framework developed by Lockheed Martin to describe the stages of a cyberattack.
- It shows how attackers move from initial reconnaissance to achieving their final goal.
- It helps security teams understand attacker behaviour and identify opportunities to detect and stop attacks.

3. The 7 Stages of the Cyber Kill Chain (Lockheed Martin)

1 Reconnaissance	2 Weaponization	3 Delivery	4 Exploitation	5 Installation	6 Command and Control (C2)	7 Actions on Objectives
Gather information about the target (e.g., employees, domains, technologies).	Create a malicious payload (e.g., malware, malicious document).	Send the weapon to the target (e.g., phishing email, malicious link).	Trigger a vulnerability to execute the payload.	Install malware or a backdoor on the target system.	Establish communication with the attacker's infrastructure.	Carry out the final goal (e.g., data theft, ransomware, destruction).
Goal: Find potential entry points.	**Goal:** Deliver a weapon to the target.	**Goal:** Get the payload to the victim.	**Goal:** Gain initial access.	**Goal:** Maintain persistence.	**Goal:** Remote control and further instructions.	**Goal:** Achieve the attacker's objective.

4. Example: Ransomware Intrusion Using the Kill Chain

Stage	Real-World Example	Attacker Activity	Potential Detection / Defense
Reconnaissance	Collect employee emails from LinkedIn.	Search for targets.	Monitor for OSINT and suspicious scanning.
Weaponization	Create a malicious document with a macro.	Build malware payload.	Email security, sandboxing.
Delivery	Send phishing email to an employee.	Deliver the payload.	Email filtering, user training.
Exploitation	Victim opens the file and macro runs.	Exploit vulnerability.	Patch systems, application controls.
Installation	Ransomware is installed on the system.	Install malware.	Endpoint detection and response (EDR).
Command and Control	Victim system connects to attacker's server.	Establish C2 channel.	Network monitoring, block malicious traffic.
Actions on Objectives	Files are encrypted and ransom note displayed.	Encrypt data and demand ransom.	Detect unusual file activity, backup and recovery.

5. Where Defenders Can Detect or Disrupt

Reconnaissance
Detect unusual scanning, OSINT activities.

Delivery
Block malicious emails and links.

Exploitation
Patch vulnerabilities and use intrusion detection.

Installation
Detect suspicious processes and file changes.

Command and Control
Monitor and block malicious outbound traffic.

Actions on Objectives
Detect data exfiltration, ransomware behaviour and abnormal account activity.

6. Practice: Trace a Simplified Ransomware Attack

Step	Scenario	Identify the Kill Chain Stage
1	Attacker finds employee emails on a company website.	?
2	Sends a phishing email with a malicious attachment.	?
3	User opens the file and malware runs.	?
4	Ransomware is installed and creates a registry key.	?
5	System connects to an external IP for commands.	?
6	Files are encrypted and a ransom note is displaatyed.	?

7. Key Takeaways

- The Cyber Kill Chain shows the typical stages of a cyberattack.
- Attackers move step by step from reconnaissance to their final objective.
- Defenders can detect or disrupt attacks at multiple stages.
- No single control stops everything, so layered security is important.
- Understanding the Kill Chain helps you investigate attacks and improve detection.

Malware and Ransomware Intelligence

VERIQTA

1. What You Will Learn

- Understand trojans, worms, spyware, ransomware, and loaders.
- Learn how analysts use malware reports and file hashes.
- Understand malware families, variants, and attribution uncertainty.
- Practice: Review a published malware analysis report.

2. Common Types of Malware

Trojan	Worm	Spyware	Ransomware	Loader
• Disguises as legitimate software. • Gives unauthorized access. • **Example:** Remote Access Trojan (RAT).	• Self-replicates across networks. • Spreads without user action. • **Example:** Conficker, WannaCry.	• Monitors user activity. • Steals data (e.g., credentials, keystrokes). • **Example:** Emotet (infostealer modules).	• Encrypts files and demands payment. • Disrupts business operations. • **Example:** LockBit, BlackCat, Conti.	• Drops and executes other malware. • Often used to deliver ransomware or stealers. • **Example:** BazarLoader, IcedID.

3. Malware Analysis Information from Reports

Information	What It Tells You	Example
File name	Common names used by the malware.	invoice.exe
File hash (MD5)	Unique fingerprint of the file.	d41d8cd98f00b204e9800998ecf8427e
File hash (SHA256)	More secure and widely used fingerprint.	3a7bd3e2360a3d92f4b7e4e91c7e2d4a6f9b3c8e1a4d5f67890abcdef1234
File type	Type of file (e.g., exe, dll, scr, docm).	exe
File size	Size can help identify variants.	345,600 bytes
Detection names	Names used by security vendors.	Trojan.Generic, Emotet, LockBit
Behaviour	What the malware does on the system.	Steals credentials, creates persistence, encrypts files

4. Malware Families and Variants

Family	Main Characteristics	Known Variants
Emotet	Modular malware, started as a banking trojan, now delivers other malware.	Emotet v1, v2, v3
TrickBot	Banking trojan, credential theft, lateral movement.	TrickBot v1, v2
QakBot (Qbot)	Banking trojan, delivers ransomware.	QakBot v1, v2
Cobalt Strike (Beacons)	Legitimate tool often abused by attackers.	Various custom beacons
LockBit	Ransomware, double extortion.	LockBit 2.0, LockBit 3.0
BlackCat (ALPHV)	Ransomware with advanced evasion techniques.	ALPHV v1, v2
Conti	Ransomware, known for large-scale attacks.	Conti v1, v2, v3

5. How Analysts Use Malware Reports

Collect reports
From vendors, researchers and threat intelligence platforms.

→ **Extract indicators**
File hashes, IP addresses, domains, URLs and detection names.

→ **Analyze behaviour**
Understand what the malware does and how it operates.

→ **Link to campaigns**
Identify related infrastructure and actors.

→ **Assess attribution**
Determine confidence level (high, medium or low).

6. Ransomware Intelligence: What to Look For



1. Ransom note and message patterns.
2. File extensions used after encryption.
3. Known file hashes of ransomware samples.
4. Associated domains, IP addresses and wallets.
5. Tools and techniques used for initial access.
6. Links to a known ransomware family.
7. Victim targeting and industry focus.

7. Practice: Review a Published Malware Analysis Report

- Choose a real malware analysis report (e.g., from a trusted security vendor).
- Identify the malware type and family.
- Note the file hashes, detection names and key behaviours.
- Look for any indicators (domains, IPs, URLs) related to the malware.
- Summarize the findings and explain how it could be detected and prevented.

8. Key Takeaways

- Malware comes in different forms, each with specific goals.
- Analysts use reports, file hashes and behaviour analysis to understand malware.
- Families and variants help track evolution, but attribution is not always certain.
- Ransomware uses multiple techniques and often targets specific industries.
- Studying real reports improves your analysis and detection skills.

Phishing and Credential Theft Intelligence

VERIQTA

1. What You Will Learn

- Understand phishing infrastructure and credential harvesting.
- Examine sender domains, suspicious URLs, and email headers.
- Learn common phishing investigation mistakes.
- Practice: Analyze a simulated phishing email.

2. What Is Phishing?



- Phishing is a social engineering attack that tricks users into giving sensitive information (e.g., login credentials, financial details).
- Attackers use fake emails, websites, and messages that look legitimate.
- The goal is usually credential theft, financial fraud or initial access to a network.

3. Common Phishing Infrastructure

Lookalike Domains

- Domains that look similar to legitimate ones (e.g., micr0soft.com).
- Often used in phishing campaigns.

Malicious URLs

- Links to fake login pages.
- Can use URL shorteners or obfuscation techniques.

Phishing Emails

- Appear to come from trusted senders.
- Use urgent or fear-based messages.

Fake Login Pages

- Mimic legitimate websites.
- Capture usernames and passwords.

4. Key Elements to Investigate

Sender Details	• Check the sender email address. • Look for spoofed or lookalike domains.
Suspicious URLs	• Hover over links to see the real URL. • Check for misspellings or use of shorteners (e.g., bit.ly).
Email Headers	• Verify the real sending server (SPF, DKIM, DMARC). • Look for unusual routing or foreign IP addresses.
Domain Information	• Check WHOIS/RDAP for registration details. • Look for recently registered domains.
Content Analysis	• Look for urgent language, threats or requests for sensitive information. • Check for grammatical errors or unusual tone.

5. Example: Suspicious Phishing Email

From: Microsoft Support <security@micr0soft.com>
Subject: Your account will be locked

Lookalike domain (micr0soft.com)

Dear User,
Your Microsoft account will be locked in 24 hours due to suspicious activity. Click the link below to verify your account and avoid suspension.

Urgent message to create fear

Verify Your Account

http://micr0soft-secure.com/login

Suspicious link (not a Microsoft domain)

6. Email Header Analysis (Key Fields)

Header Field	What to Check
From	Is the sender address legitimate or spoofed?
Return-Path	Check the actual sending domain.
Received	Look for unusual or foreign IP addresses.
SPF	Should show if the email is authorized.
DKIM	Verify if the signature is valid.
DMARC	Check the policy (pass, fail or none).

7. Common Phishing Investigation Mistakes

1. Only checking the visible sender name (not the actual email address).
2. Clicking links or opening attachments.
3. Ignoring email headers.
4. Not checking domain age and registration details.
5. Assuming a single indicator (e.g., one tool result) is enough.
6. Missing context (e.g., targeted industry or campaign).

8. Practice: Analyze a Simulated Phishing Email

Investigation Task	Your Findings
1. Identify the sender domain.	_____
2. Check the real URL.	_____
3. Review key header fields.	_____
4. Look up the domain (WHOIS).	_____
5. Identify red flags in the content.	_____
6. Determine if it is phishing.	_____
7. Explain your reasoning.	_____

9. Key Takeaways

- Phishing uses fake emails, domains and websites to steal credentials.
- Always check sender details, URLs, email headers and domain information.
- Be aware of common investigation mistakes.
- Use multiple sources and context before making a conclusion.
- Practice analyzing real or simulated phishing emails to build your skills.

Threat Intelligence Feeds and Data Quality

1. What You Will Learn

- Understand commercial, community, and open-source intelligence feeds.
- Learn freshness, confidence, relevance, and false-positive risks.
- Understand why more indicators do not automatically mean better intelligence.
- Practice: Compare two intelligence sources.

2. Types of Threat Intelligence Feeds

Commercial Feeds

- Provided by security vendors.
- Often include global data, research and analysis.
- Usually higher cost.
- **Examples:** Recorded Future, Mandiant, ThreatConnect.

Community Feeds

- Shared by the security community.
- Often free or low cost.
- Useful for real-time threats and collaborative data.
- **Examples:** AlienVault OTX, MISP, Abuse.ch.

Open-Source Feeds

- Publicly available data.
- Includes government, research and vendor reports.
- Free to use.
- **Examples:** CERT/CSIRT reports, CISA, GitHub, security blogs.

3. Key Data Quality Factors

Factor	What It Means	Why It Matters
Freshness	How recent the data is.	Outdated indicators may no longer be relevant.
Confidence	The reliability of the source and the data.	Helps you decide how much to trust the indicator.
Relevance	How useful the data is for your environment.	Not all indicators apply to your industry or region.
False Positives	Legitimate items incorrectly flagged as malicious.	Can waste time and resources.

4. Example Threat Intelligence Feeds

Feed / Source	Type	What It Provides	Notes
VirusTotal	Open Source	File, URL, IP and domain reputation.	Good for initial checks, multi-engine results.
AlienVault OTX	Community	IP, domain, URL, file hashes, threat pulses.	Community-driven, free to use.
AbuseIPDB	Community	Reports and reputation for IP addresses.	Useful for investigating suspicious IPs.
MISP	Community / Open Source	Threat sharing platform for indicators.	Popular in SOC and CTI teams.
Recorded Future	Commercial	Global threat data and analysis.	Paid, high-quality, wide coverage.

5. Data Quality Example

Source A (Open Source)

- **IP Address:** 185.199.110.153
- **First Seen:** 2024-08-10
- **Last Seen:** 2024-08-12
- **Reports:** 3
- **Confidence:** Low
- **Context:** Reported in a single blog post.

May be useful, but limited data and lower confidence.

Source B (Commercial)

- **IP Address:** 185.199.110.153
- **First Seen:** 2024-08-10
- **Last Seen:** 2025-10-01
- **Reports:** 25+ (multiple sources)
- **Confidence:** High
- **Context:** Associated with a malware campaign targeting multiple industries.

More complete data, higher confidence and more relevant context.

6. Why More Indicators Do Not Always Mean Better Intelligence

1. **Low-quality data:** Many indicators can be outdated or incorrect.
2. **Irrelevant data:** Not all indicators apply to your environment.
3. **Higher false positives:** More data can increase noise.
4. **Lack of context:** Indicators without context are harder to use.
5. **Quality over quantity:** A small number of high-confidence, relevant indicators is more valuable.

7. Practice: Compare Two Intelligence Sources

Criteria	Source A	Source B	Which Is Better? (A or B)
Freshness (recent data)	?	?	?
Confidence (reliability)	?	?	?
Relevance (useful for your environment)	?	?	?
Number of reports	?	?	?
Context and analysis	?	?	?
Final conclusion			

8. Key Takeaways

- Choose the right type of feed for your needs.
- Always check freshness, confidence, relevance and false-positive risks.
- More indicators do not automatically mean better intelligence.
- Combine multiple sources and use context.
- Good data quality improves accuracy and decision-making.

STIX and TAXII Explained Simply

1. What You Will Learn

- Understand Structured Threat Information Expression (STIX).
- Understand Trusted Automated Exchange of Intelligence Information (TAXII).
- Learn how intelligence can be represented and shared between tools.
- Practice: Read a simplified STIX indicator object.

2. What Are STIX and TAXII?

STIX
(Structured Threat Information Expression)

- A standard language for representing cyber threat intelligence.
- Uses a structured format (usually JSON).
- Defines objects such as indicators, malware, threat actors, campaigns, etc.
- Helps tools understand and share the same threat information.

TAXII
(Trusted Automated Exchange of Intelligence Information)

- A standard protocol for sharing STIX data between tools.
- Allows automated exchange of threat intelligence.
- Uses HTTPS for secure and trusted sharing.
- Enables organizations to send and receive STIX objects from threat intel platforms and communities.

3. How STIX and TAXII Work Together

STIX → TAXII → Security Tools

STIX	TAXII	Security Tools
Threat information is structured in STIX format (e.g., indicators, malware, threat actors).	TAXII protocol is used to share the STIX data automatically between tools and platforms.	Tools ingest the data and use it for detection, analysis and response (e.g., SIEM, SOAR, threat intel platforms).

4. Common STIX Object Types

Object Type	Description	Example Use
Indicator	Represents a observable such as an IP address, domain, URL or file hash.	Detect malicious activity.
Malware	Describes malware families and their characteristics.	Track and understand malware threats.
Threat Actor	Represents the attacker or group behind activity.	Attribute attacks to known groups.
Campaign	Groups related activity targeting a specific goal.	Understand larger attack operations.
Vulnerability	Represents a security weakness.	Link threats to known vulnerabilities.

5. Simplified STIX Indicator Object (JSON)

```
{
  "type": "indicator",                                  ← Type of object (indicator)
  "id": "indicator--f4c2d7e8-1b3a-4e5f-9c6d-1234567890ab",  ← Unique ID for this object
  "spec_version": "2.1",
  "created": "2024-08-12T10:00:00Z",                    ← When it was created
  "modified": "2024-08-12T10:00:00Z",
  "name": "Malicious IP Address",
  "description": "IP address associated with a known malware campaign.",   ← Short description
  "indicator_types": ["malicious-activity"],
  "pattern": "[ipv4-addr:value = '185.199.110.153']",   ← The actual indicator (in this case an IP address)
  "valid_from": "2024-08-12T10:00:00Z"
}
```

6. Example: Sharing STIX with TAXII

STIX Data (Indicators, Malware, Threat Actors, etc.) → TAXII Server (Threat Intel Platform) → TAXII Client (Security Tool)

1. STIX objects are created and stored on a TAXII server.
2. A security tool (TAXII client) connects to the server using TAXII over HTTPS.
3. The tool automatically pulls or receives the STIX data.
4. The data is used for detection, alerting and analysis.

7. Practice: Read a STIX Indicator

1. Look at the STIX indicator object above.
2. Identify the type of indicator.
3. Find the indicator value (IP address).
4. Note when it was created.
5. Explain what this indicator could be used for.

8. Key Takeaways

- STIX standardizes how threat information is represented.
- TAXII standardizes how that information is shared.
- STIX and TAXII work together to enable automated threat intelligence sharing.
- Structured data improves accuracy, interoperability and faster response.
- Always check the source, context and confidence of the intelligence.

Threat Actor Profiling and Attribution

VERIQTA

1. What You Will Learn

- Learn how analysts investigate threat actor behavior.
- Understand infrastructure reuse, targeting, and observed techniques.
- Distinguish evidence from assumptions.
- Understand why attribution requires careful confidence assessment.
- Practice: Create an evidence-based threat actor profile.

2. What Is Threat Actor Profiling?



- Threat actor profiling is the process of collecting and analyzing information to understand who is behind an attack.
- It helps identify patterns in behaviour, techniques, infrastructure and targets.
- Profiles can include motivations, capabilities, resources and likely goals.
- Attribution is the process of linking activity to a specific actor, group or state, based on evidence and with a defined confidence level.

3. Information Used for Profiling

TTPs	**Infrastructure**	**Targeting**	**Malware**	**Campaigns**
Observed techniques, tactics and procedures.	IP addresses, domains, hosting providers, SSL certificates.	Industries, countries, organizations and specific sectors.	File hashes, malware families, code similarities and unique features.	Phishing themes, lures, timelines and attack patterns.
Behaviour	**Historical Data**	**Open Sources**	**Victimology**	**Artifacts**
Working hours, language, tools, and operational patterns.	Previous campaigns and long-term activity.	Reports, blogs, threat intel feeds and public research.	Types of victims, regions, and repeated targets.	Unique code, configuration errors, metadata and reused elements.

4. Attribution Confidence Levels

Level	Meaning	Description
High	Strong evidence	Multiple independent and consistent sources link the activity to the actor.
Medium	Moderate evidence	Some evidence with limited correlation.
Low	Limited evidence	Weak or indirect evidence to support the link.
None	Insufficient evidence	Not enough evidence to make an attribution.

5. Example: Threat Actor Profile (Simplified)

Actor Name	APT28 (Fancy Bear)
Type	State-sponsored group
Probable Origin	Russia (high confidence)
Motivation	Espionage, geopolitical influence
Common Targets	Government, military, energy, think tanks
Common TTPs	Spear phishing, malware, credential theft, lateral movement
Known Malware	Sofacy, X-Agent, Zebrocy
Infrastructure	Reused domains, known IP ranges, bulletproof hosting
Attribution Confidence	High (based on multiple independent sources)

6. Evidence vs. Assumptions

Evidence (Facts)	Assumptions (Not Enough)
✓ Reused malware code.	✗ Same language used.
✓ Same infrastructure (IP/domain).	✗ Similar working hours.
✓ Similar techniques and tools.	✗ Believed country of origin.
✓ Overlapping targeting patterns.	✗ Single source report.
✓ Metadata and configuration similarities.	✗ Similar victim industry only.
✓ Independent reporting from multiple sources.	✗ Speculation without technical evidence.

7. Practice: Create a Threat Actor Profile

1. Choose a real or publicly documented threat actor (e.g., APT28, Lazarus, FIN7, or a ransomware group).
2. Research their TTPs, infrastructure, malware and targeting.
3. Collect evidence from trusted sources (reports, blogs, threat intel feeds).
4. Summarize your findings in a profile (as shown in example above).
5. State your attribution confidence level and explain your reasoning.

8. Key Takeaways

- Threat actor profiling combines multiple types of evidence.
- Attribution requires careful analysis and confidence assessment.
- Infrastructure and TTP reuse are strong indicators but not definitive.
- Always separate factual evidence from assumptions.
- Use multiple independent sources.
- A clear, structured profile helps communicate findings effectively.

Turning Threat Data Into Actionable Intelligence

VERIQTA

1. What You Will Learn

- Define a security intelligence question.
- Collect and correlate relevant evidence.
- Evaluate source reliability and analytical confidence.
- Develop findings, limitations, and recommendations.
- Practice: Produce a short intelligence assessment.

2. From Data to Intelligence

Data	Information	Intelligence	Action
Raw information from multiple sources (e.g., logs, reports, IOCs, open source).	Organized and contextualized data (e.g., related events, correlated indicators).	Analyzed information that answers a specific question (e.g., who, what, why, how, impact).	Decisions and measures (e.g., detect, block, investigate, mitigate).

3. Steps to Create Actionable Intelligence

1 Define the Question	2 Collect Evidence	3 Analyze and Correlate	4 Evaluate Confidence	5 Produce Findings
• Be specific about what you need to know. • Define scope, time period and objectives.	• Gather data from trusted sources. • Include multiple types (IOCs, reports, logs, context).	• Look for patterns and relationships. • Correlate across multiple sources and timelines.	• Assess source reliability. • Consider data quality, consistency and alternative explanations.	• Summarize key findings. • State limitations. • Provide clear recommendations.

4. Example Intelligence Question

Question: Is a recent increase in suspicious login attempts related to a known threat actor campaign?

Scope	Corporate email environment
Time Period	Last 30 days
Key Data Needed	Login logs, IP addresses, threat intel reports
Desired Outcome	Confirm if activity is linked and recommend defensive actions

5. Sources of Evidence

Open Source	Commercial	Internal	Community
• Threat intel feeds • Security blogs • News reports • Social media • Public repositories	• Vendor threat feeds • Malware analysis reports • Reputation data • Attack campaign tracking	• Firewall logs • Endpoint logs • Email security logs • SIEM alerts • Incident reports	• ISAC/ISAO reports • CERT advisories • Threat sharing platforms • Research communities

6. Assessing Source Reliability

Reliability Level	Meaning	Examples
High	Trusted, verified and consistent.	Government CERT, well-known security vendors, official reports.
Medium	Generally reliable but may have limitations.	Reputable blogs, industry partners, community feeds.
Low	Unverified or limited information.	Social media posts, anonymous sources, unverified reports.
Unknown	Cannot be verified yet.	New sources or insufficient details.

7. Example: Short Intelligence Assessment

Title	Suspicious Activity Targeting Corporate Email
Key Findings	• Multiple malicious login attempts from known VPN IP ranges. • Activity matches techniques used by Threat Actor APT28. • Similar phishing emails observed in open-source reports.
Confidence	Medium (some evidence, not all indicators match).
Limitations	• Limited visibility into external recipient activity. • Some indicators are shared by multiple threat actors.
Recommendations	• Block identified IP addresses. • Increase monitoring for similar phishing emails. • Conduct further investigation on affected accounts.

8. Practice: Create a Short Assessment

1. Choose a simple scenario (e.g., suspicious login activity, malicious domain, or phishing campaign).
2. Define your intelligence question.
3. Collect at least three pieces of evidence from different sources (e.g., log data, threat intel report, open source).
4. Analyze and correlate the evidence.
5. Write a short assessment with findings, limitations and recommendations.

9. Key Takeaways

- Good intelligence starts with a clear question.
- Use multiple sources and look for patterns.
- Always assess source reliability and confidence.
- More data does not automatically mean better intelligence.
- Be transparent about limitations.
- Actionable intelligence leads to better security decisions.

Threat Intelligence in the SOC

VERIQTA

1. What You Will Learn

- Understand how CTI supports security monitoring.
- Learn the basics of Security Information and Event Management (SIEM).
- Connect intelligence to alerts, investigations, and detection rules.
- Understand why unverified indicators should not automatically trigger blocking.
- Practice: Investigate a simulated SIEM alert using CTI.

2. How Threat Intelligence Fits in the SOC

Threat Intelligence (CTI)
Provides indicators, context and actor information (e.g., IPs, domains, hashes, TTPs).

→

SIEM
Ingests logs, correlates events and matches indicators to find suspicious activity.

→

Alerts
Generates alerts based on rules, correlations and threat intelligence.

→

Investigation & Response
Analysts investigate using intelligence, confirm true or false positives, and take action.

3. What is a SIEM?

A SIEM (Security Information and Event Management) collects, stores, and analyzes log data from multiple sources (e.g., firewalls, endpoints, cloud, apps) to detect, investigate and respond to security threats.

Common SIEM Data Sources

Firewalls	Endpoints	Cloud Services	Servers	Network Devices	Applications
Network traffic logs	EDR/AV logs	CloudTrail, Azure Activity Logs, etc.	System and application logs	IDS/IPS, VPN, DNS logs	Web, email and database logs

4. Using CTI in the SIEM

Ingest Indicators	Add IPs, domains, hashes, and URLs from trusted CTI sources.
Correlation	Match indicators with log data and look for related activity.
Context Enrichment	Add threat actor, malware, TTPs, and reputation context.
Alert Prioritization	Help identify high-risk alerts and reduce false positives.
Investigation Support	Use CTI to confirm, expand and understand the scope of an alert.

5. Example: SIEM Alert with Threat Intelligence

SIEM Alert Details	
Time	2026-10-14 10:22:45
Source IP	185.199.110.153
Destination	10.0.5.27
Event	Multiple failed login attempts
Log Source	VPN (Firewall)
Severity	High

Threat Intelligence Enrichment	
IP Reputation	Malicious
Associated Actor	APT28 (Fancy Bear)
Related TTPs	T1110 (Brute Force)
Additional Context	Seen in recent phishing campaigns

6. Investigation Steps

1	**Validate the indicator**	Check IP/domain in multiple CTI sources (e.g., VirusTotal, AlienVault, MISP).
2	**Review related logs**	Look for additional activity (e.g., successful logins, lateral movement, persistence).
3	**Check context**	Identify associated malware, threat actor and campaign.
4	**Determine impact**	Confirm if the activity affected any systems or data.
5	**Take action**	Block if confirmed malicious, create detection rule, and document findings.

7. Why Not Automatically Block Unverified Indicators?

- Indicators can be shared hosting, VPNs or legitimate services.
- False positives can disrupt business operations.
- Context and verification are required before blocking.
- Use confidence levels and multiple sources.
- Blocking should be based on validated, high-confidence intelligence.

8. Key Takeaways

- CTI helps the SOC detect and investigate threats faster.
- The SIEM is the central platform for log collection and correlation.
- Always validate indicators and use context.
- Unverified indicators should not automatically trigger blocking.
- CTI improves alert quality, investigation depth and response decisions.

9. Practice: Investigate a Simulated SIEM Alert Using CTI

1. Review the alert details provided.
2. Use at least two threat intelligence sources to investigate the indicator (IP, domain or hash).
3. Identify the possible threat actor, related TTPs and campaign.
4. Determine if the alert is malicious or a false positive.
5. Write a short investigation summary with findings and recommendations.

Threat Hunting With Intelligence

1. What You Will Learn

- Understand the difference between reactive investigation and proactive hunting.
- Build a simple hypothesis using known attacker behavior.
- Identify useful logs and supporting evidence.
- Learn how to validate or reject a hunting hypothesis.
- Practice: Design a basic threat-hunting investigation.

2. Reactive Investigation vs. Proactive Hunting

Reactive Investigation

- Triggered by an alert or known incident.
- Focused on confirming, containing and responding.
- Uses existing indicators and information.
- Answers: "What happened? Is this malicious?"

Preactive Threat Hunting

- Initiated without a specific alert.
- Looks for hidden or unknown threats.
- Uses threat intelligence, attacker behavior and hypotheses.
- Focuses on finding suspicious activity early.
- Answers: "What else might be happening in our environment?"

3. Building a Hunting Hypothesis

Threat Intelligence → **Hypothesis** → **Data to Search** → **Expected Findings**

- Known attacker TTPs (MITRE ATT&CK), malware, IOCs, campaigns.
- Example: "Attackers may use PowerShell to download and execute malware."
- Windows logs
- Process logs
- Network logs
- DNS logs
- Proxy logs
- Cloud logs
- EDR logs
- Suspicious processes
- Unusual connections
- Known malicious domains/IPs
- Behavior matching TTPs

4. Useful Logs for Threat Hunting

Log Source	What It Provides	Hunting Examples
Windows	Process, file, login, registry, PowerShell	Unusual processes, script execution, lateral movement
Network	NetFlow, firewall, DNS, proxy logs	Suspicious connections, beaconing, data exfiltration.
Endpoint/ EDR	Process, file, registry, behavior alerts	Malware execution, privilege escalation
Cloud	CloudTrail, activity logs, API logs	Unusual API calls, unauthorized access
Email	Email logs, phishing reports	Suspicious sender domains, malicious attachments/URLs

5. Example: Hunting for Suspicious PowerShell Activity

Hypothesis

Attackers may use PowerShell to download and execute payloads (ATT&CK T1059.001).

Search Logic (SIEM Query Example)

```
index=win_logs (EventCode=4104 OR EventCode=4688)
| search powershell OR "-enc" OR "IEX" OR "DownloadString"
| stats count by host, user, process, command_line
```

Look For

- Encoded commands
- DownloadString
- IEX (Invoke-Expression)
- Suspicious URLs
- Execution from temp folders

6. Validate or Reject the Hypothesis

1. **Analyze the results** – Review the activity and check for malicious behavior.
2. **Correlate with threat intelligence** – Compare findings with known IOCs, TTPs or malware families.
3. **Check context** – Identify if the activity is legitimate (e.g., admin activity, software deployment).
4. **Validate or reject** – Decide if the hypothesis is supported or not.
5. **Document findings** – Include evidence, reasoning and next steps.

7. Simple Threat-Hunting Investigation Plan

Step	Action	Details
1. Define objective	What are we looking for?	E.g., possible malware execution using PowerShell.
2. Build hypothesis	Based on threat intelligence.	Use known TTPs and recent campaigns.
3. Identify data sources	Which logs will help?	Endpoint, network, DNS, cloud, email.
4. Search and analyze	Run queries and review.	Look for suspicious patterns.
5. Validate findings	Is it malicious or benign?	Check context and additional evidence.
6. Document results	Write a short report.	Include findings, limitations and recommendations.

8. Key Takeaways

- Threat hunting finds threats that may not generate alerts.
- Use threat intelligence and attacker behavior to build hypotheess.
- Look for suspicious patterns across multiple log sources.
- Always validate findings with context.
- Not every suspicious activity is malicious.
- Document your findings and recommendations.
- Practice regularly to improve hunting skills.

Writing Your First Threat Intelligence Report

VERIQTA

1. What You Will Learn

- Structure an intelligence report for a defined audience.
- Write an executive summary and technical findings.
- Document evidence, confidence, limitations, and recommended actions.
- Distinguish confirmed facts from analytical judgments.
- Practice: Prepare a one-page intelligence report.

2. Who Reads Threat Intelligence Reports?

Executive Leadership

- Needs high-level risk and impact.
- Short, clear summary.
- Focus on business impact and recommended actions.

Security Teams (SOC)

- Needs technical details and IOCs.
- Uses findings for detection, investigation, and response.
- Needs clear confidence levels.

IT Operations

- Needs actions that reduce risk.
- Focus on practical steps (e.g., block, patch, monitor).
- Needs clear timelines.

Legal, Compliance and Others

- Needs factual, objective information.
- May require attribution confidence and source details.
- Needs clear limitations.

3. Typical Structure of a Threat Intelligence Report

1	Title and Metadata	Clear and specific title, date, author, and distribution level.
2	Executive Summary	Key findings, impact and recommended actions (short and non-technical).
3	Background	Context, why the report was produced and what is known.
4	Technical Findings	Detailed analysis of activity, TTPs, infrastructure, IOCs.
5	Evidence	Data sources, logs, reports, screenshots, file hashes, URLs.
6	Confidence Assessment	Level of confidence (high, medium, low) with reasoning.
7	Limitations	What is unknown and constraints in the analysis.
8	Recommendations	Clear, actionable steps for the intended audience.

4. Example Report Layout (One-Page)

Threat Intelligence Report

Date: 2026-10-14
Author: SOC Analyst
Audience: Security Team
TLP: Amber

Executive Summary

Short summary of the threat, impact and key recommendations.

Key Findings

- Main findings (3–5 key points).

Technical Details

- Attacker activity, TTPs, IOCs (IPs, domains, hashes, URLs).
- Relevant logs and evidence.

Confidence Assessment

- Confidence level (High / Medium / Low) with justification.

Limitations

- What is unknown or could not be verified.

Recommended Actions

- Specific and actionable steps.
- Prioritized by importance.

5. Confirmed Facts vs. Analytical Judgments

Confirmed Facts

- Directly supported by evidence (e.g., logs, file hashes, network data).
- Can be verified and replicated.
- Should be clearly referenced.
- Use neutral, factual language.

Example (Fact):

"The IP address 185,199.110.153 was observed making multiple failed login attempts on 2026-10-12."

Analytical Judgments

- Based on analysis, interpretation and available evidence.
- May not be 100% certain.
- Should include a confidence level.
- Use language such as "likely", "possible" or "assessed".

Example (Judgment):

"This activity is likely associated with the APT28 threat actor based on infrastructure overlap and known TTPs."

6. Confidence Levels

Level	Meaning	Description
High	We are confident this is correct.	Multiple consistent sources and strong evidence.
Medium	We are moderately confident.	Some evidence, but gaps or limited sources.
Low	We have limited confidence.	Weak evidence or contradictory information.
Unknown	We cannot assess confidence.	Not enough information available.

7. Practice: Prepare a One-Page Intelligence Report

1. Choose a recent threat (e.g., phishing campaign, malware, known threat actor).
2. Gather and review evidence from at least two sources (e.g., logs, reports, IOCs).
3. Write a one-page report using the structure above.
4. Include an executive summary, key findings, confidence level and recommendations.
5. Keep it clear, concise and appropriate for your intended audience.

8. Key Takeaways

- A good report is clear, accurate and audience-focused.
- Separate facts from analytical judgments.
- Use evidence to support your analysis.
- Always include confidence levels and limitations.
- Provide practical and actionable recommendations.
- Keep it concise and structured.

Your First Complete CTI Investigation

VERIQTA

1. Scenario Overview

A company's security team receives reports of suspicious phishing emails targeting employee Microsoft 365 accounts.

Your Goal

Conduct a complete Cyber Threat Intelligence (CTI) investigation using the provided evidence and produce a concise intelligence report.

2. What You Will Do

1. Define the intelligence requirements.
2. Review the supplied phishing evidence.
3. Extract suspicious domains, URLs, and IP addresses.
4. Investigate indicators using passive intelligence sources.
5. Identify relevant MITRE ATT&CK techniques.
6. Evaluate source reliability and confidence.
7. Explain possible organizational impact.
8. Recommend appropriate defensive actions.
9. Produce a concise threat intelligence report.
10. Present the findings to a simulated SOC team.

3. Example Phishing Email (Evidence)

From: Microsoft Support <security@micros0ft-updates.com>
To: employee@company.com
Subject: Action Required: Verify Your Microsoft 365 Account

Dear User,

Your Microsoft 365 account will be suspended due to unusual activity. Please verify your account within 24 hours to avoid permanent closure.

Verify Account

Suspicious Elements:

- Spoofed sender domain
- Urgent language
- Suspicious URL
- Requests credentials
- Threat of account closure

4. Extract Indicators

Indicator Type	Example from Email	Notes
Domain	micros0ft-updates.com	Suspicious lookalike domain
URL	hxxps://micros0ft-updates.com/login	Potential credential harvesting page
IP Address	185.199.110.153	Host associated with phishing infrastructure
Email Address	security@micros0ft-updates.com	Likely spoofed sender
File Hash (if attachment)	d41d8cd98f00b204e9800998ecf8427e	Check in threat intelligence sources

5. Investigate Ushing Passive Intelligence Sources

VirusTotal
- Check domain, URL, IP and file hash.
- View detection results and community information.

WHOIS
- Domain registration details.
- Creation date, registrant, hosting provider.

URLScan
- Analyze website content and behavior.
- Screenshots and detected technologies.

AlienVault OTX
- Check for related indicators.
- See community reports and pulses.

AbuseIPDB
- Check IP reputation and abuse reports.

Any.Run
- Analyze suspicious files or URLs in a safe environment.

GreyNoise
- Check if IP is known for malicious activity.

Passive DNS
- Find related domains, subdomains and historical IPs.

6. Map to MITRE ATT&CK

Tactic	Technique	How It Applies
Initial Access	T1566 (Phishing)	Attackers use phishing emails to trick users into revealing credentials.
Credential Access	T1110 (Brute Force)	Stolen credentials may be used for account takeover.
Defense Evasion	T1566.002 (Spearphishing Link)	Uses malicious links to a fake Microsoft 365 login page.
Collection	T1119 (Credential Access)	Harvests user credentials.
Impact	T1528 (Account Access Removal)	Could lead to account takeover and data exposure.

7. Evaluate and Analyze

Source Reliability

Source	Reliability
Government/Official (e.g., CISA)	High
Reputable security vendors	High
Known community sources	Medium
Blogs / unverified reports	Low
Unknown or single source	Low

Analytical Confidence

Level	Meaning
High	Strong evidence from multiple reliable sources.
Medium	Some evidence, but gaps exist.
Low	Limited or indirect evidence.
Unknown	Not enough information to assess.

8. Final Deliverable: CTI Report

- **Executive Summary**
  Key findings and impact.
- **Technical Findings**
  Indicators, analysis and MITRE ATT&CK mapping.
- **Confidence Assessment**
  Reliability of sources and confidence level.
- **Organizational Impact**
  Potential risks to the business.
- **Recommended Actions**
  Short and long term defensive measures.
- **Appendix**
  Evidence (screenshots, logs, links) and references.

9. Practice: Complete the Investigation and Present Findings

1 Define requirements → 2 Review evidence → 3 Extract indicators → 4 Investigate indicators → 5 Map to MITRE ATT&CK → 6 Analyze and evaluate → 7 Write CTI report → 8 Present to SOC team